

Résumé

SafeCRM semble disposer d'un socle sérieux pour la conformité RGPD, en particulier autour de la gestion des données clients, de la gouvernance DPO, de la traçabilité des consentements et des droits des personnes. Il ne s'agit pas d'un simple CRM : le projet intègre une vraie logique de conformité, avec registre des traitements, suivi des demandes de droits, journal d'audit, gestion des incidents et workflows de suppression/archivage.

Ce que SafeCRM peut faire concrètement

1. Gérer un registre des traitements (article 30 RGPD)

SafeCRM prévoit un registre des traitements détaillé, avec :

- nom du traitement,
- finalité,
- base légale,
- catégories de données,
- destinataires,
- durées de conservation,
- sous-traitants,
- transferts de données,
- mesures de sécurité.

Le dépôt contient un registre complet couvrant plusieurs traitements, par exemple :

- gestion des comptes utilisateurs,
- gestion des contacts/prospects,
- contrats commerciaux,
- paiements,
- logs d'audit,
- collecte de prospects via formulaires web,
- dossiers victimes 17Cyber.

2. Gérer les consentements RGPD

Le module DPO propose une gestion explicite des consentements avec :

- enregistrement d'un consentement,
- traçabilité de la date d'obtention,
- possibilité de retrait,
- synchronisation avec les champs CRM liés aux consentements.

Le flux de collecte de prospects via les formulaires web est également pensé pour être conforme, avec :

- consentement obligatoire,
- horodatage,
- texte de consentement fixé côté serveur,
- stockage de la preuve de consentement.

3. Traiter les demandes d'exercice des droits (articles 15 à 22)

Le module DPO inclut un workflow pour gérer :

- droit d'accès,
- rectification,
- suppression,
- portabilité,
- opposition,
- limitation.

Les demandes sont suivies avec :

- statut,
- date de réception,
- date limite de réponse,
- réponse apportée,
- génération de documents PDF pour certaines réponses.

4. Gérer les incidents et violations de données

SafeCRM possède un module de gestion des violations de données avec :

- enregistrement des incidents,
- niveau de gravité,
- suivi des actions correctives,
- logique de notification CNIL dans le cadre de l'article 33.

Le projet prévoit donc une capacité de gestion des incidents, qui est essentielle en matière de RGPD.

5. Assurer la traçabilité et l'audit

Le CRM intègre un journal RGPD / logs d'audit, utilisé notamment pour :

- suivre les actions sensibles,
- conserver une trace des opérations,
- démontrer une logique de sécurité et de gouvernance.

Le module d'audit RGPD propose même un score de conformité, avec :

- contrôle des traitements,
- vérification des consentements,
- présence de documents réglementaires,
- suivi des demandes de droits,
- suivi des violations.

6. Gérer la suppression et l'archivage des données

Le projet prévoit une fonction de suppression utilisateur avec :

- archivage JSON des données dans un stockage Supabase,
- conservation pendant 5 ans,
- réassignation des éléments liés à l'utilisateur supprimé,
- suppression effective du compte.

C'est une fonction très intéressante pour la conformité, car elle va au-delà d'une simple suppression "visuelle".

7. Gérer les sous-traitants et les transferts de données

Le registre DPA du projet couvre :

- Supabase,
- Stripe,
- Brevo,
- Anthropic,
- xAI / Grok,
- GitHub.

Le projet documente aussi :

- les obligations liées aux sous-traitants,
- les transferts hors UE,
- la nécessité de DPA et/ou clauses contractuelles.

Ce point est important, car il montre que SafeCRM ne se limite pas aux données internes : il prend en compte l'écosystème technique autour du traitement.

Mesures techniques de sécurité et conformité

Le projet met en place plusieurs garanties techniques :

- RLS (Row Level Security) PostgreSQL,
- authentification MFA/TOTP,
- contrôles serveur sur les formulaires web,
- honeypot et rate limiting,
- CORS restreints,
- vérification HMAC des webhooks Stripe,
- chiffrement en transit et au repos,
- pseudonymisation avant certains transferts IA.

Ce sont des éléments solides pour un socle de conformité.

Limites et points à valider

Il faut toutefois rester prudent :

- certains DPA sont encore "en attente" (Brevo, Anthropic, xAI),
- l'assistant RGPD est mentionné comme "service non connecté",
- le projet vise une certification / conformité, mais il ne faut pas considérer qu'il est déjà certifié,
- la conformité RGPD dépend aussi de la politique de l'entreprise, des procédures internes et de l'usage réel du système.

Conclusion

SafeCRM semble capable de fournir un environnement assez avancé pour la gestion de la conformité RGPD, surtout pour :

- le registre des traitements,
- la gestion des consentements,
- les demandes de droits,
- l'audit et la traçabilité,
- la suppression/archivage,
- la gouvernance DPO.

En revanche, il reste important de considérer ce produit comme un outil opérationnel de conformité et de gouvernance, et non comme une “solution entièrement prête” sans contrôle juridique et organisationnel. Le dépôt montre une vraie volonté de structurer la conformité, mais certaines pièces contractuelles et procédurales restent à finaliser.

Si vous voulez, je peux aussi vous faire une version plus “professionnelle” de ce rapport, par exemple sous forme de :

- rapport de 1 page,
- synthèse executive,
- document prêt à envoyer à un client ou à un partenaire,
- version plus “compliance audit” avec forces, faiblesses, risques et recommandations.